



CIBERSEGURIDAD EN ENTORNOS DE LAS TECNOLOGÍAS DE LA INFORMACIÓN

Bastionado de redes y sistemas

TEMA 9

Configuración de los sistemas informáticos
Alberto Diéguez Álvarez

Tabla de contenido

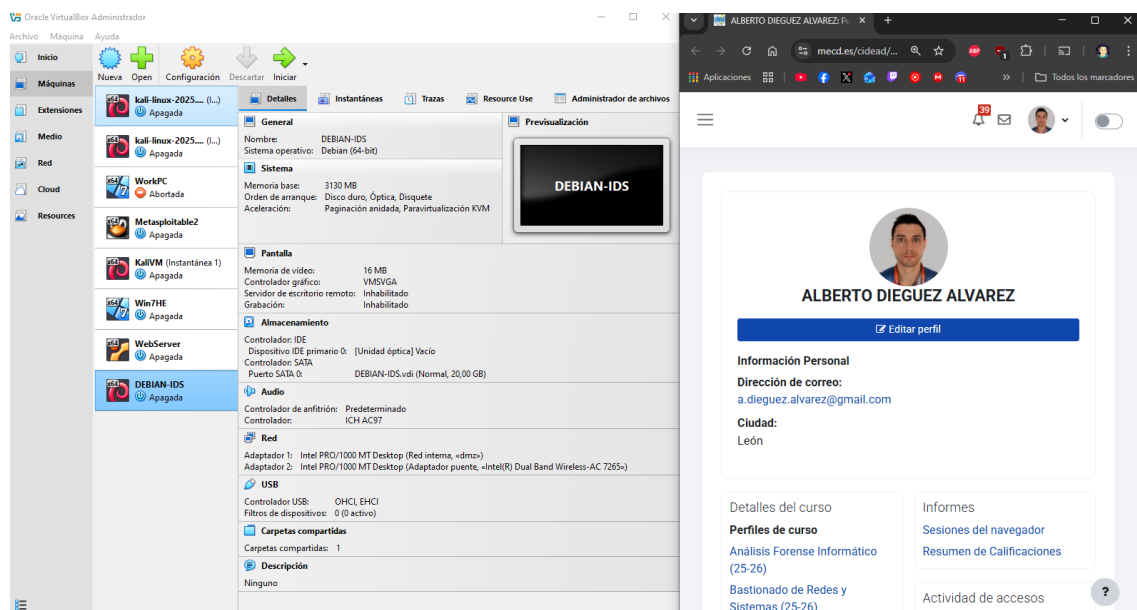
1. No será posible el acceso remoto con el usuario root.....	3
2. Si la sesión permanece sin actividad durante 5 minutos se bloqueará.	6
3. Los usuarios deberán acceder al servicio con una clave público/privada. Las claves privadas de los usuarios deberá tener configurados los permisos correctamente para que un usuario no pueda manipular claves privadas de otros usuarios.	9
4. Sólo está permitido el acceso al servicio para cierto usuario	13
5. Sólo está permitido el acceso al servicio para ciertos IPs. Basar la confianza de los equipos en parámetros de filtrado host de SSH en lugar del fichero .rhosts	15
6. Se debe implementar la versión segura del protocolo.	17
7. No es posible que a través del servicio se realice "Port-forwarding" ni "X11 Forwarding"	18
8. Los usuarios recibirán en el inicio de sesión un mensaje indicando el tipo de sistema que están accediendo y la obligación de cumplir con la normativa interna de la empresa.....	20
9. Se establecerán los algoritmos de hash SHA2-512 y SHA2-256 para garantizar la integridad de los datos... ..	22
10. Los logs del servicio están activados para poder enviárselos al SOC. .	23

¿Qué te pedimos que hagas?

Responsable de la Seguridad de la empresa ha decidido que este servicio crítico y tan utilizado por los administradores tiene que ser bastionado, de cara aumentar el nivel de seguridad de las tareas asociada a la utilización del SSH. Por lo que ha decidido que se implementen las siguientes medidas de seguridad:

1. No será posible el acceso remoto con el usuario root.

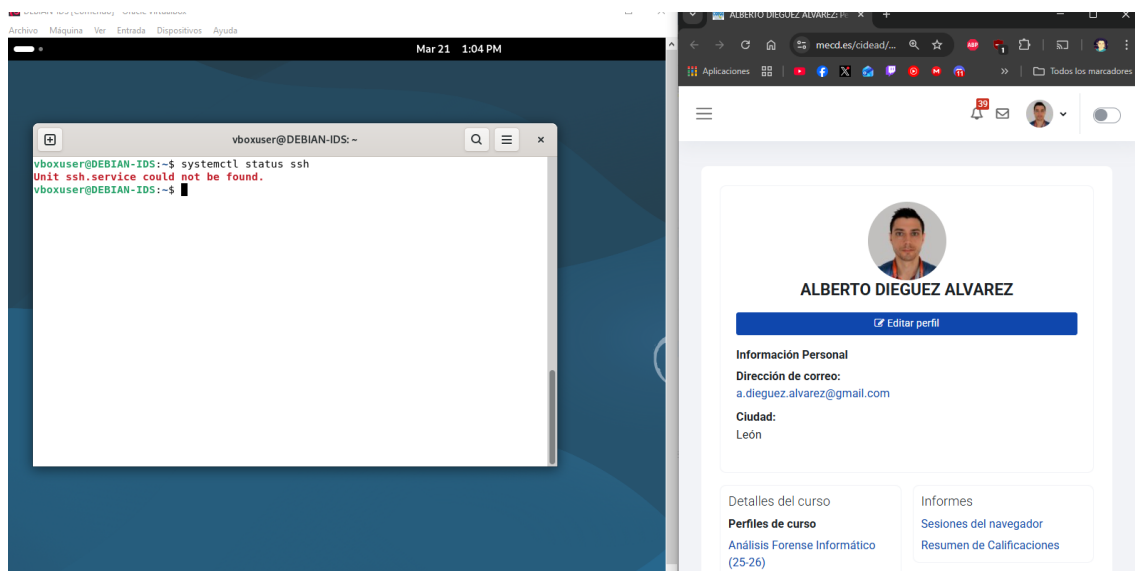
Para esta tarea utilizare una VM que he utilizado anteriormente.



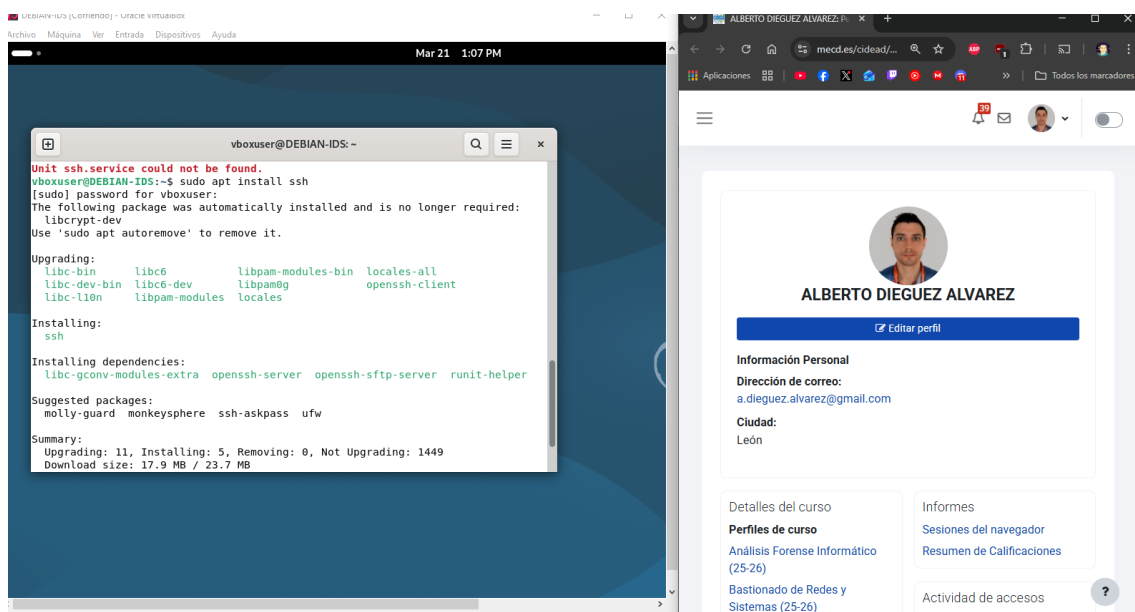
Para empezar la prueba, compruebo el estado del servicio ssh:

```
systemctl status ssh
```

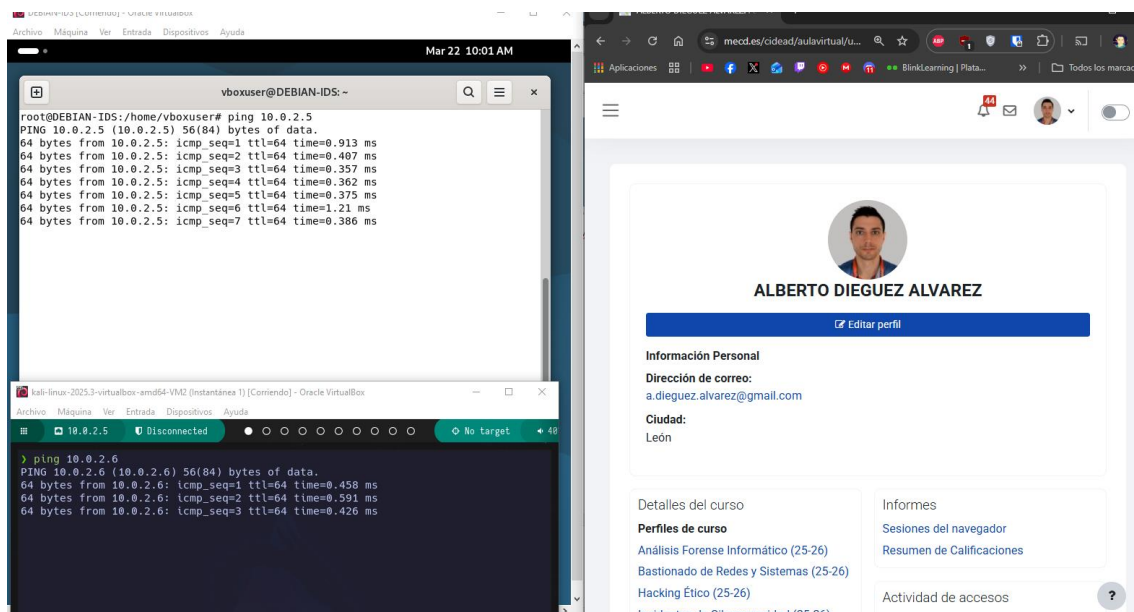
No está instalado, procedo a instalarlo:



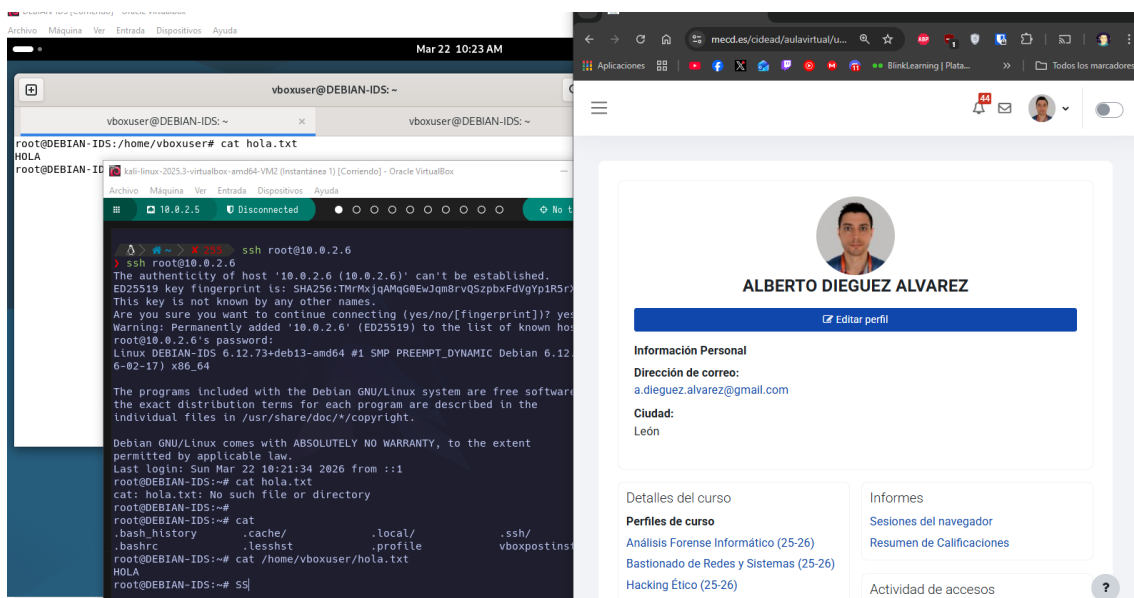
apt install ssh



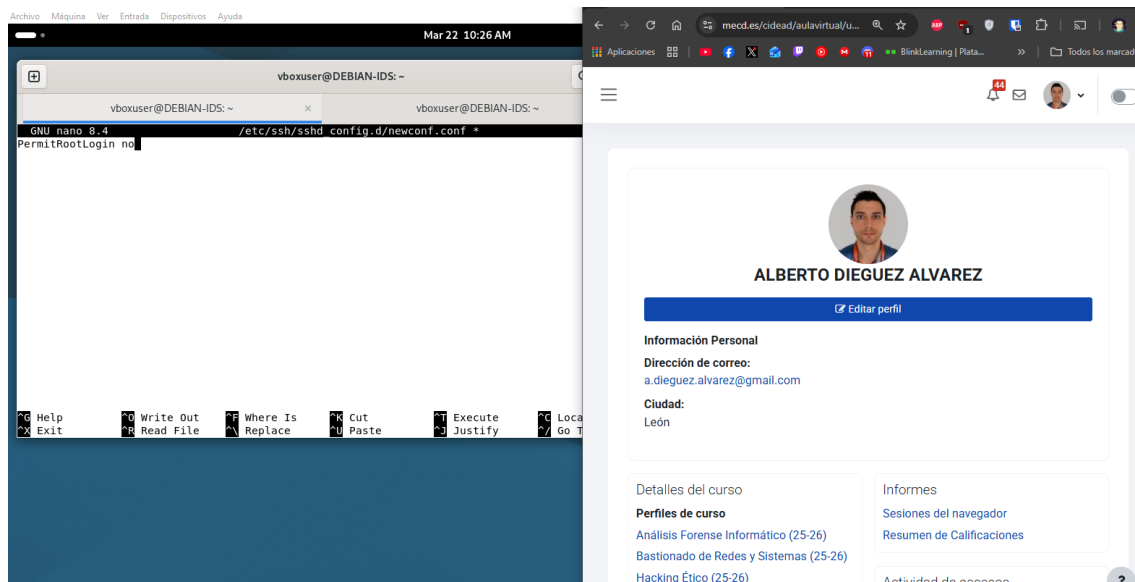
Compruebo que hay conexión entre las VMs.



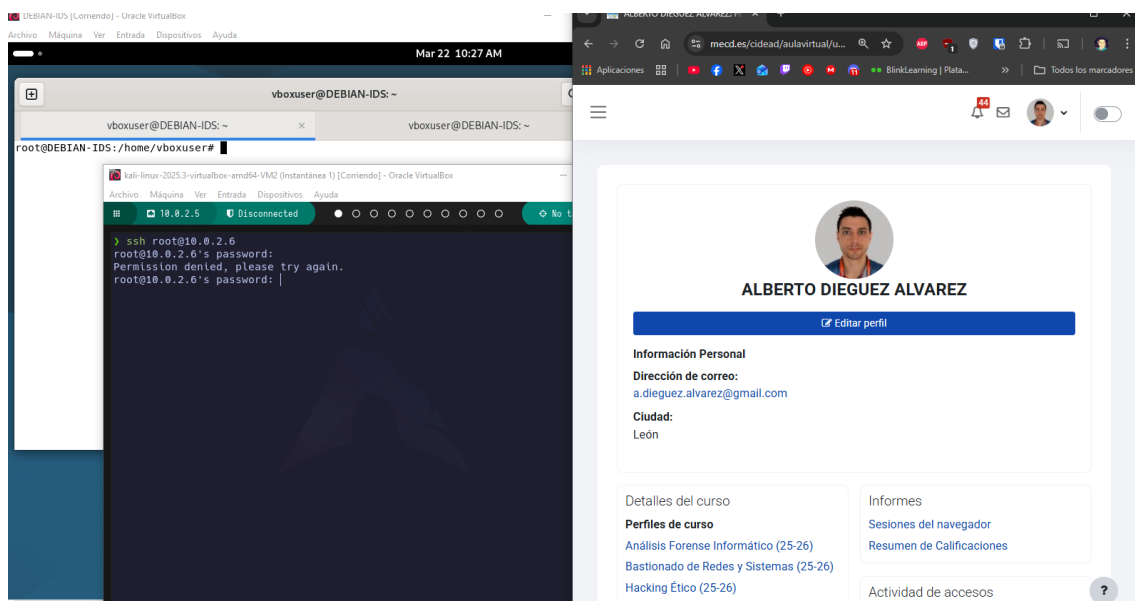
Ahora ejecuto una conexión ssh. Tuve que configurar para poder entrar por root, ya que por defecto no lo permite...



Ahora añado un nuevo archivo llamado `newconfig.conf` en `/etc/ssh/sshd\_config.d` y añado `PermitRootLogin no`



Hago restart del servicio `systemctl restart ssh` y pruebo de nuevo.

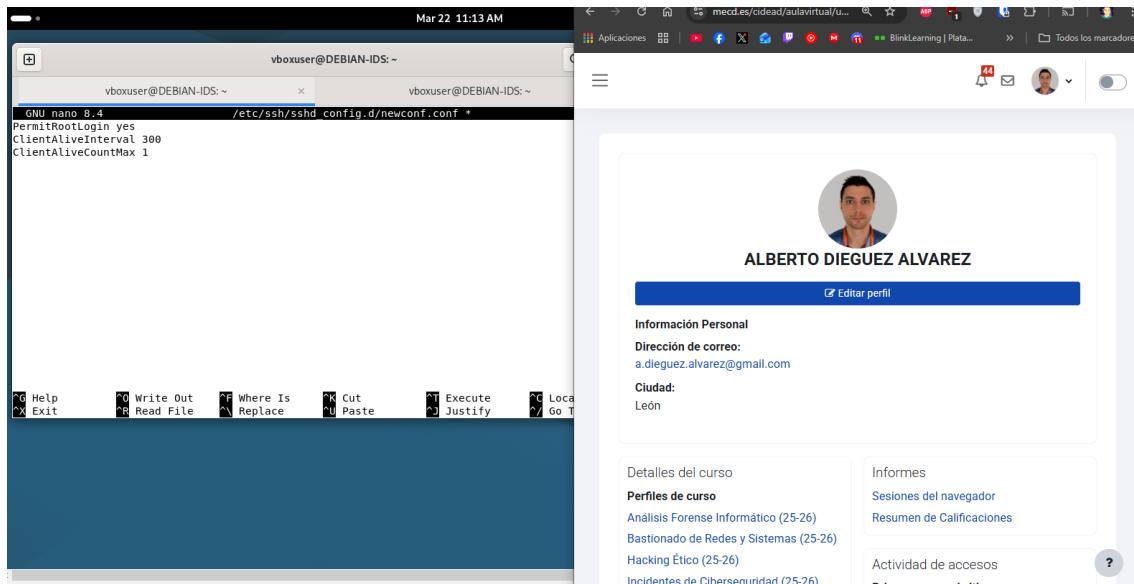


2. Si la sesión permanece sin actividad durante 5 minutos se bloqueará.

Para esto se añade al mismo archivo que he creado anteriormente o se modifica directamente el `sshd\_config` lo siguiente:

```
ClientAliveInterval 300
ClientAliveCountMax 1
```

Para esta prueba quedaría así la configuración añadida:



Probando esto, veo que solo funciona si la VM deja de recibir ping, dado que esos parámetros lo que hacen es eso, cada X tiempo ejecuta un ping y si este no contesta cierra la sesión.

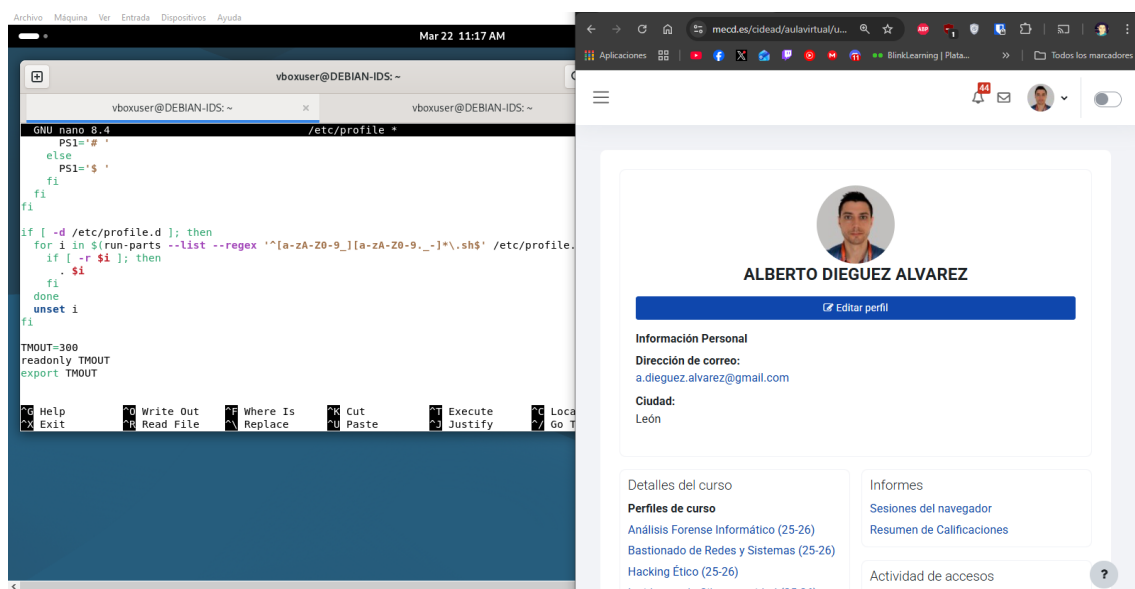
Para esto, se configurará en `/etc/profile` con la variable de entorno: `TMOUT` que controla la inactividad del usuario. La configuración sería la siguiente.

```
TMOUT=300
readonly TMOUT
export TMOUT
```

Con TMOUT configuramos el tiempo sin actividad para cerrar la sesión de la Shell.

Con `readonly TMOUT` ponemos la variable solo como lectura y no podrá ser modificada durante la sesión.

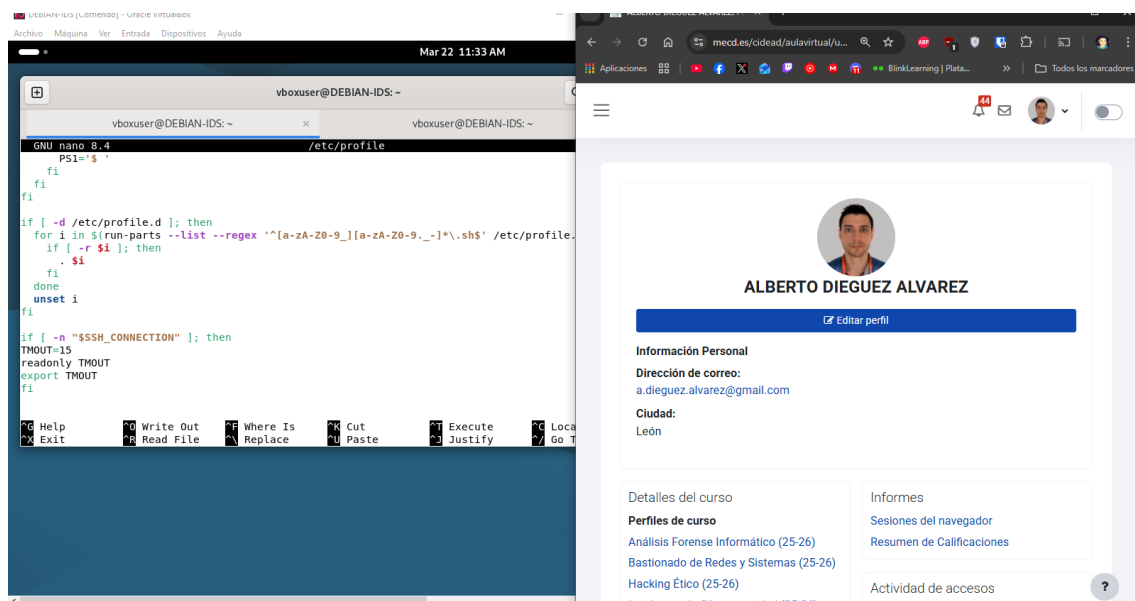
Y con export TMOUT exportamos las variables para que sea visible por todos los procesos.



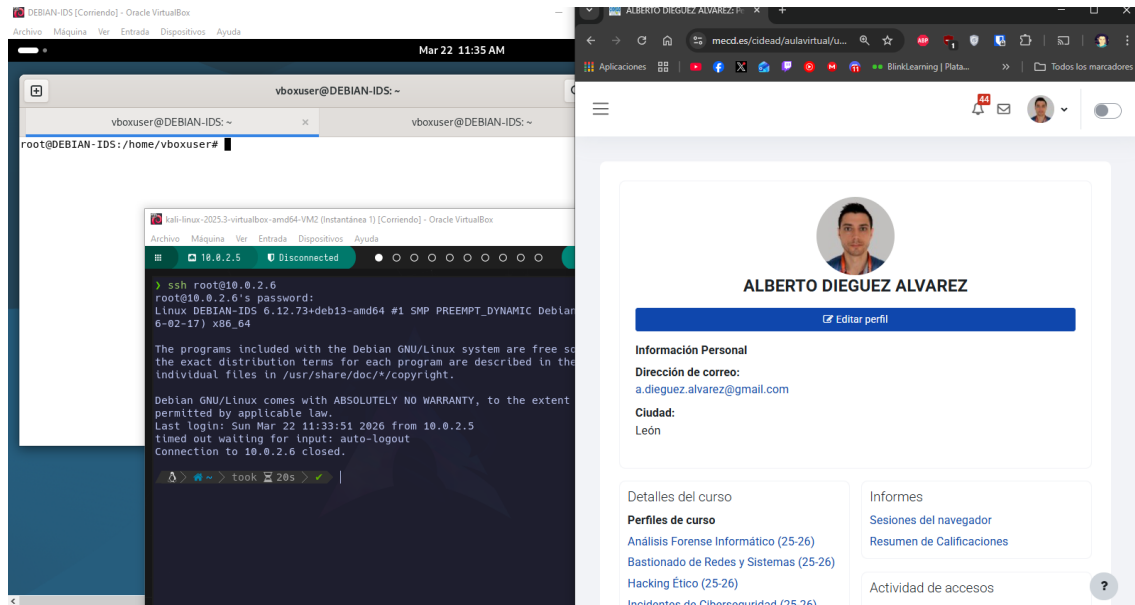
Para este test, lo pruebo con 15 segundos.

Después de hacer varias pruebas, veo que con esa configuración, también se cierra la terminal de la VM que recibe el ssh, para ello he encontrado esta configuración, comprobando que hay conexiones ssh y entonces funciona bien.

```
if [ -n "$SSH_CONNECTION" ]; then
    TMOUT=300
    readonly TMOUT
    export TMOUT
fi
```



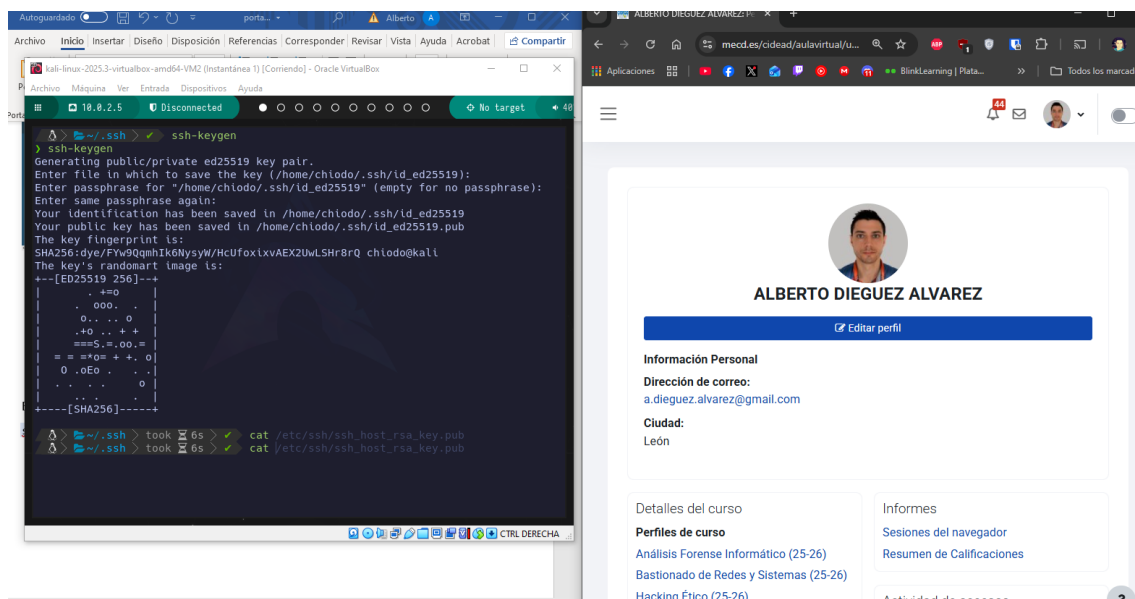
Realizo el test. Aquí se puede ver el tiempo que ha llevado la operación que pone 20s, porque tuve que poner el password y se ve que en la VM receptora no se cierra la terminal como root.



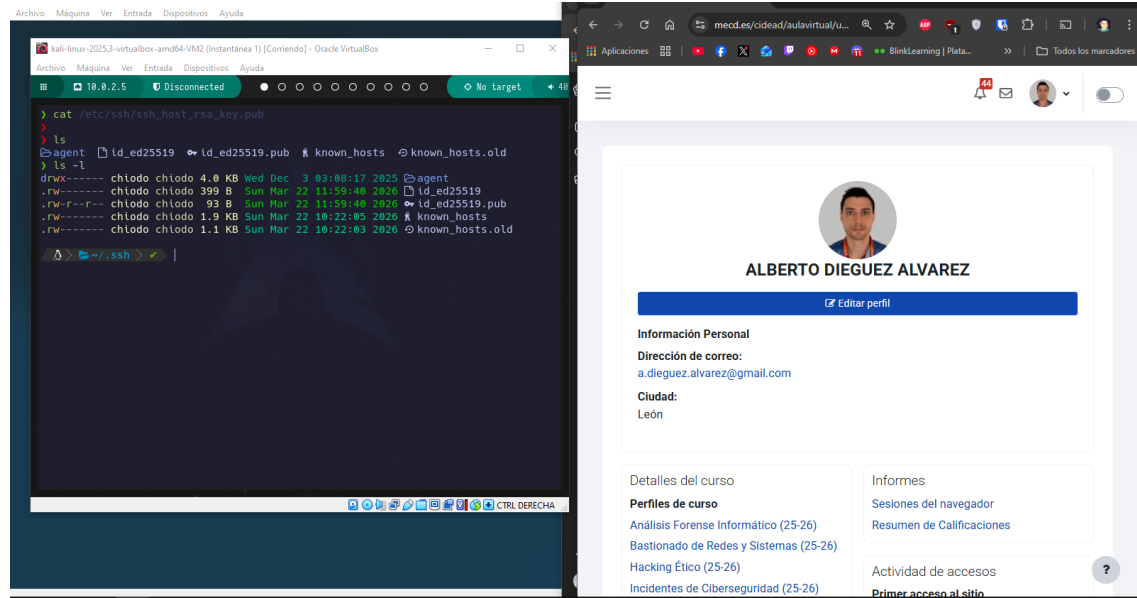
3. Los usuarios deberán acceder al servicio con una clave público/privada. Las claves privadas de los usuarios deberá tener configurados los permisos correctamente para que un usuario no pueda manipular claves privadas de otros usuarios.

En la VM usuario (Kali), creo la ssh_key:

ssh-keygen



Compruebo los permisos.



Se puede ser que tienen los siguientes permisos:

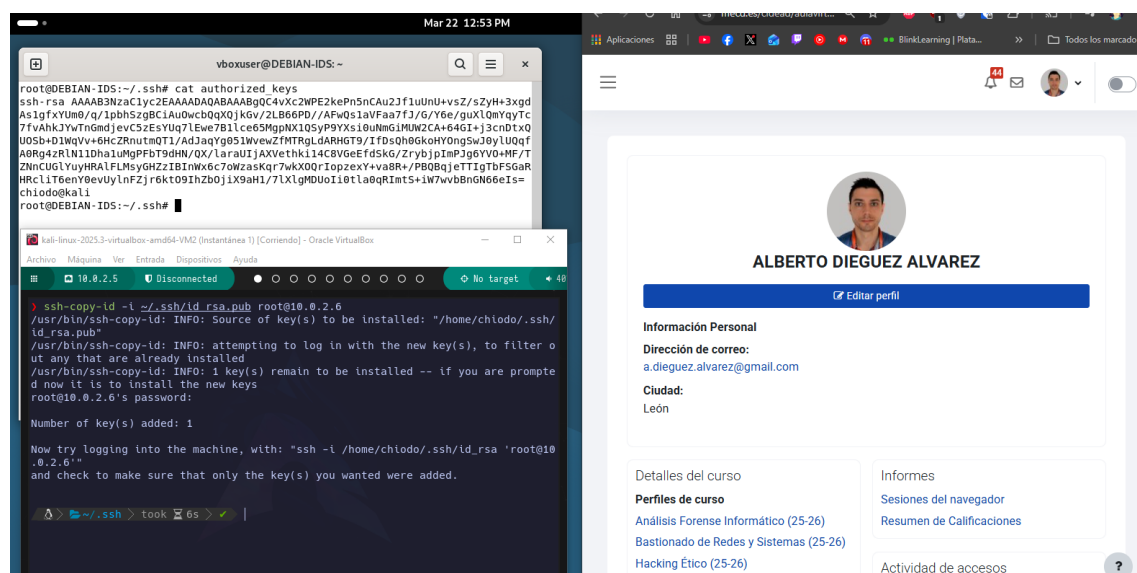
➤ ls -l

drwx----- chiodo chiodo 4.0 KB Wed Dec 3 03:08:17 2025 agent # solo el user puede entrar 700

.rw----- chiodo chiodo 399 B Sun Mar 22 11:59:40 2026 id_ed25519 # clave privada, solo el usuario puede leer o escribir 600

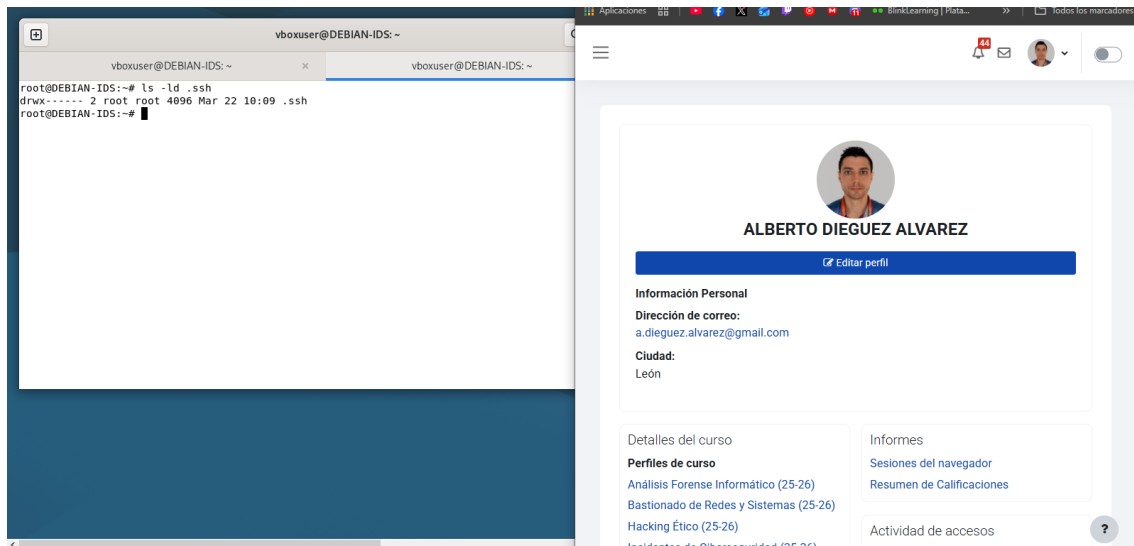
.rw-r--r-- chiodo chiodo 93 B Sun Mar 22 11:59:40 2026 id_ed25519.pub # clave pública, solo el usuario puede leer y escribir pero cualquiera puede leer

Ya tenemos la ssh_key del usuario (Kali), me genero otra, pero con -t rsa, para probar más cosas y como puedo acceder como root a la VM (Debian), ejecuto el ssh-copy-id y compruebo que está en `authorized_keys`

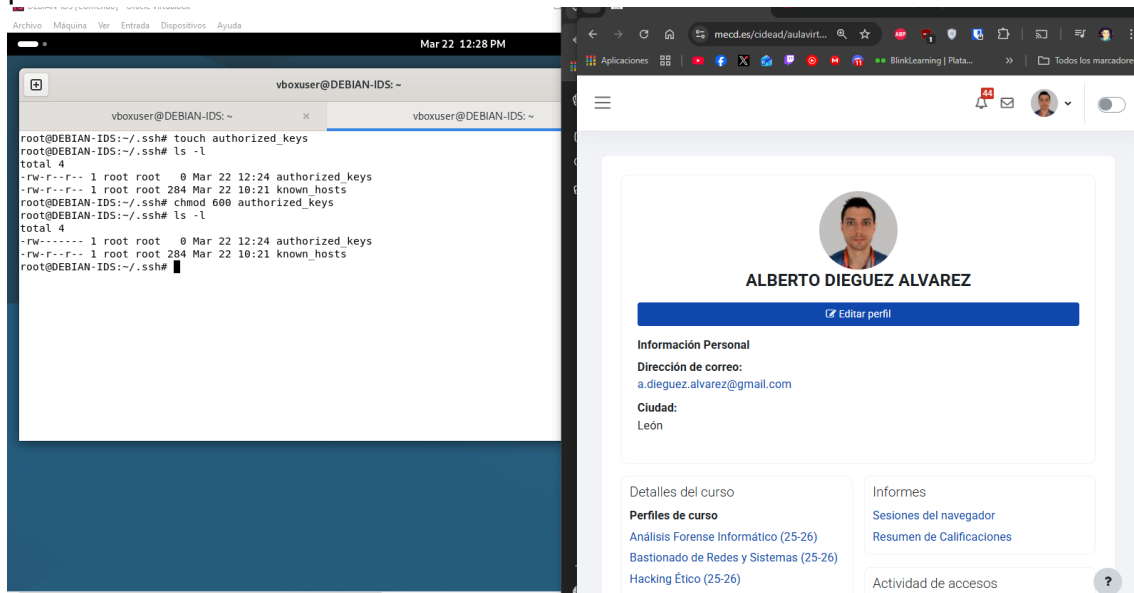


Pasamos a configurar la VM cliente (Debian).

Compruebo los permisos de la carpeta ``.ssh``.



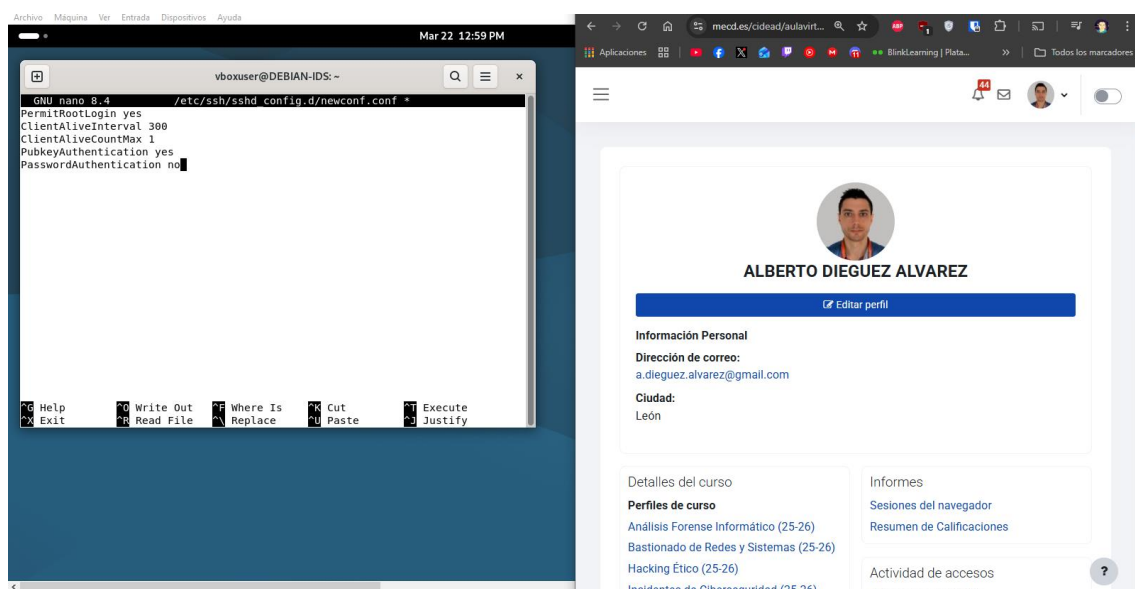
Tiene permisos 700, es decir. El propietario tiene todos los permisos y los grupos y otros usuarios no tienen ningún permiso. Está correcto para la tarea. Ahora compruebo los permisos del archivo `authorized_keys`, y como veo que tiene 644 y cualquiera lo puedo leer, lo modifico a 600 para que nadie más lo pueda leer.



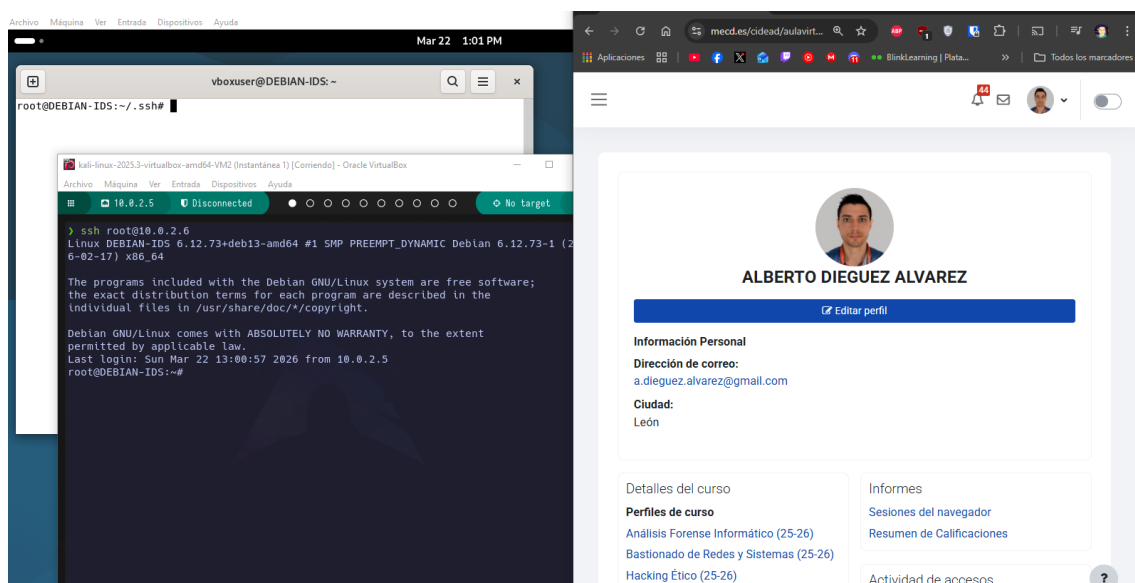
Debido a las pruebas que he estado realizando, algunos pasos, como este de crear las carpetas, se han creado antes de ejecutar `ssh-copy-id`.

Ahora termino de configurar la VM (Debian).

PubkeyAuthentication yes
PasswordAuthentication no



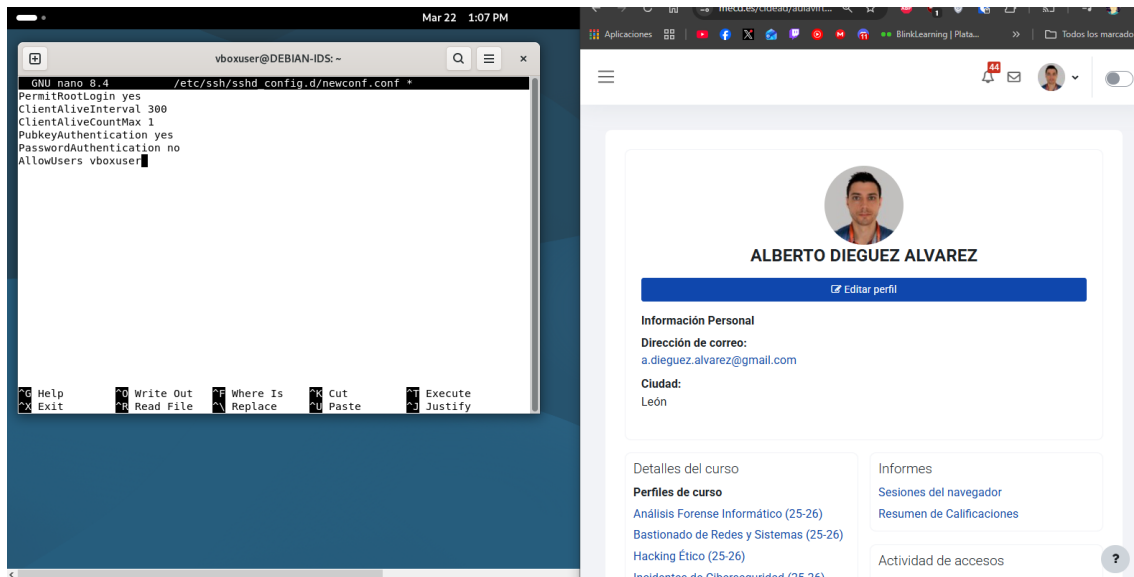
Se nos conecta sin pedir password:



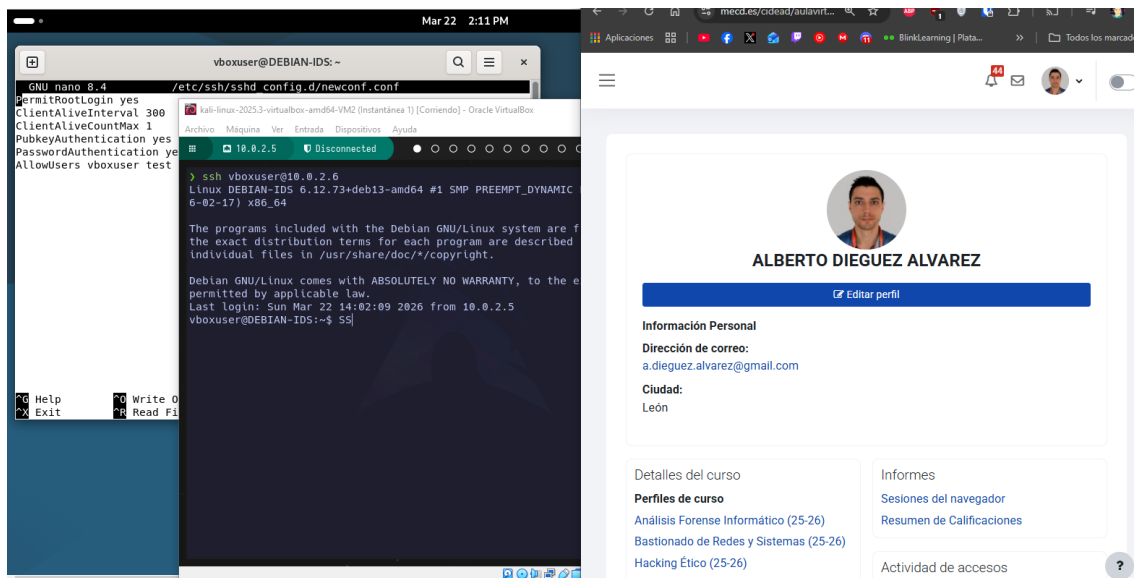
Si quisiéramos conexiones solo por publickey, habría que configurar la configuración con `AuthenticationMethods publickey`.

4. Sólo está permitido el acceso al servicio para cierto usuario

Configuro sshd_config con `AllowUsers`

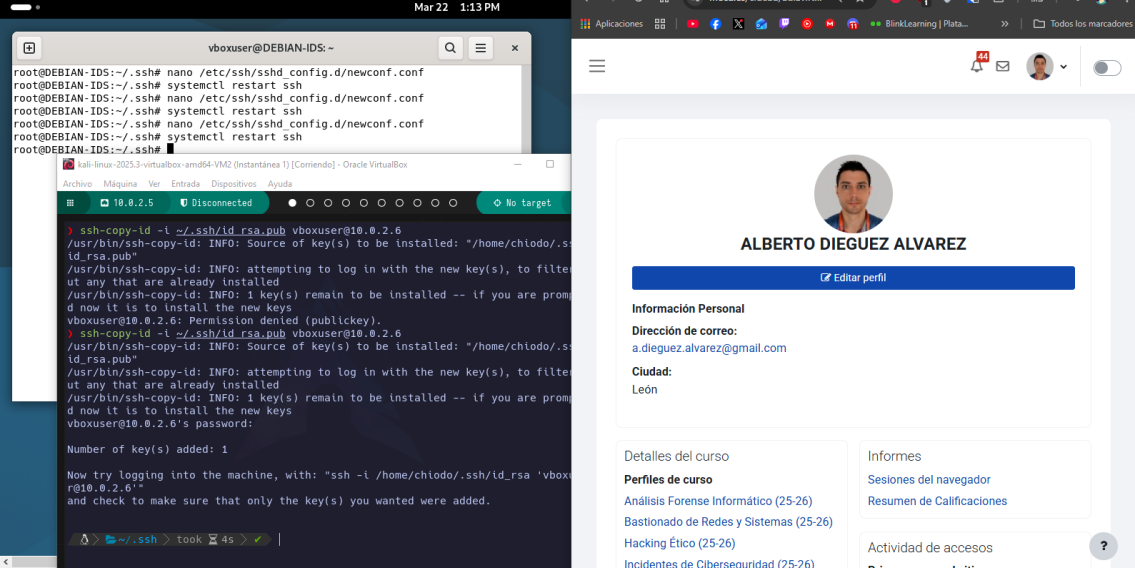


Reinicio el servicio y pruebo.

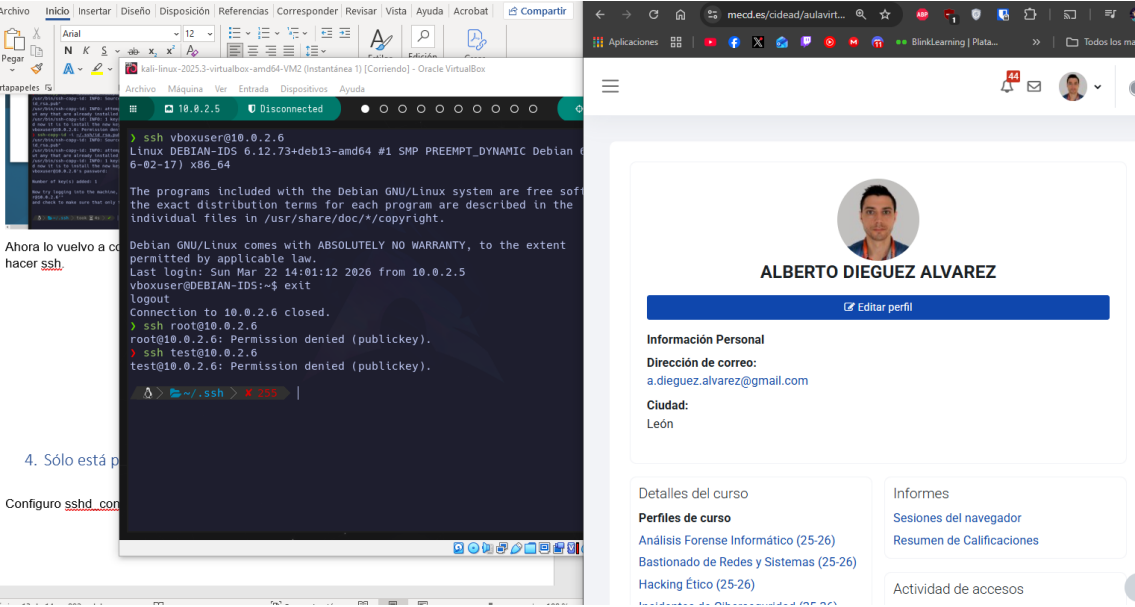


Dado que antes había puesto con ssh-copy-id en root, ahora tuve que deshacer los cambios o más bien añadir desde mi VM Kali la pubkey a vboxuser. Aquí se

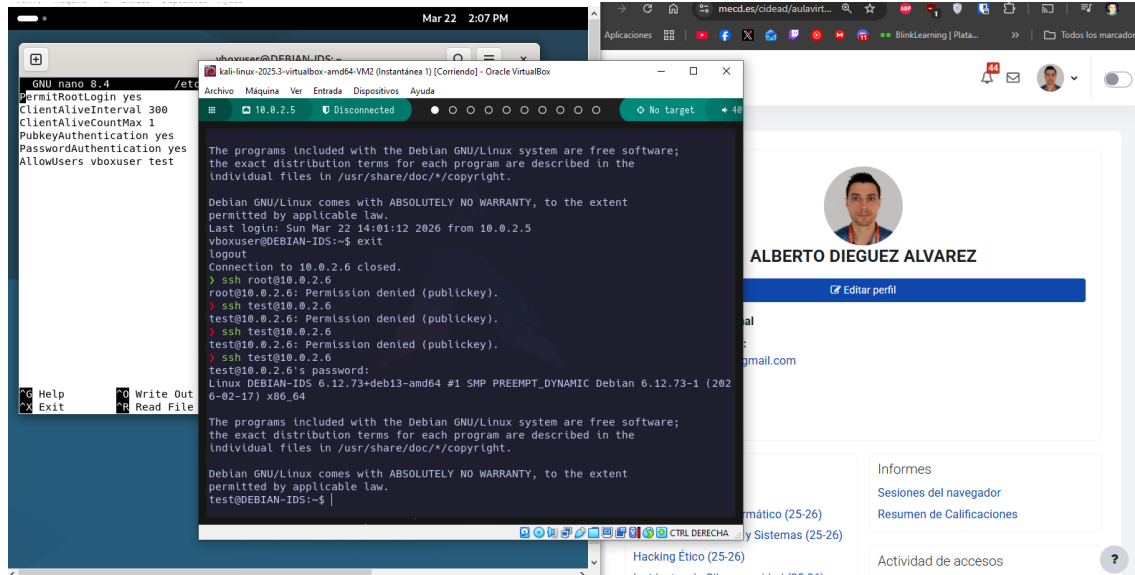
ven los cambios:



Ahora lo vuelvo a configurar como antes. Creo un nuevo user test y pruebo hacer ssh.



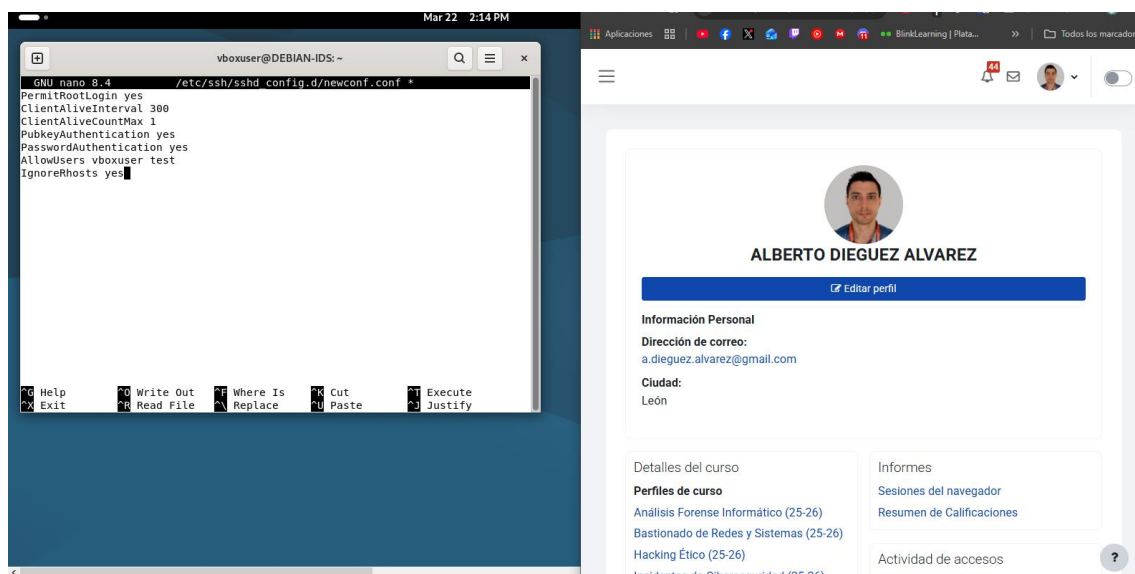
Ahora añado test a ssh_config y pruebo ssh.



Como con el user test, no había añadido la pubkey, habilité el password, y así ya puedo conectarme. Jugando con la configuración se puede hacer todo tipo de permisos entre conexiones.

5. Sólo está permitido el acceso al servicio para cierto IPs.
Basar la confianza de los equipos en parámetros de filtrado
host de SSH en lugar del fichero `.rhosts`

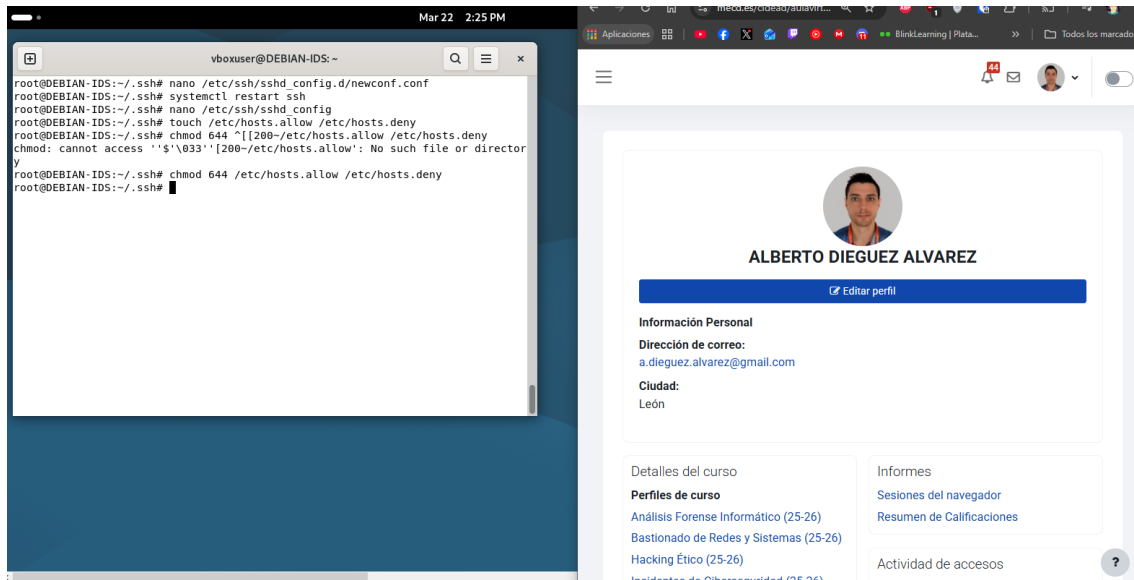
Activamos la directiva `IgnoreRhosts` en `/etc/ssh/sshd_config/newconfig.conf` ya que es el archivo que he creado.



Y reiniciamos configuración con ``systemctl restart ssh``.

Ahora creo los siguientes archivos.

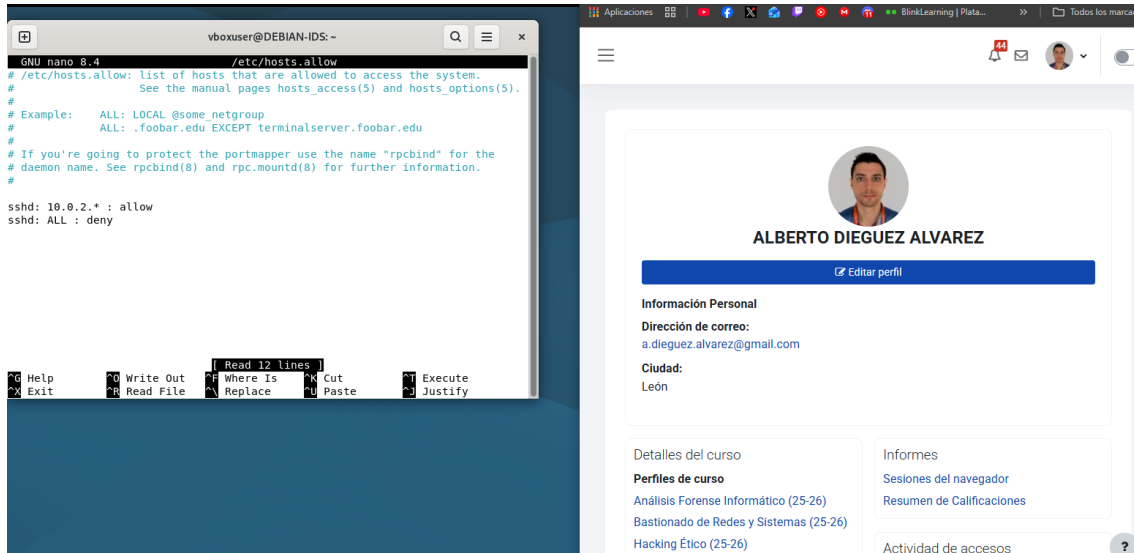
```
touch /etc/hosts.allow /etc/hosts.deny
chmod 644 /etc/hosts.allow /etc/hosts.deny
```



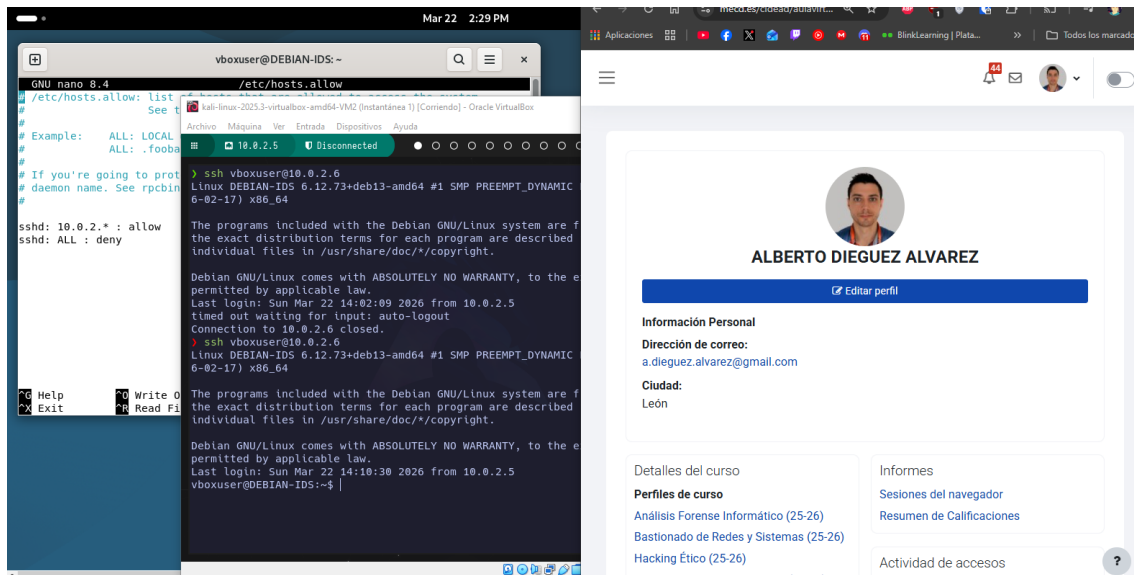
Los configuro con lo que se pide. Añado esto a hosts.allow

```
sshd: 10.0.2.* : allow
sshd: ALL : deny
```

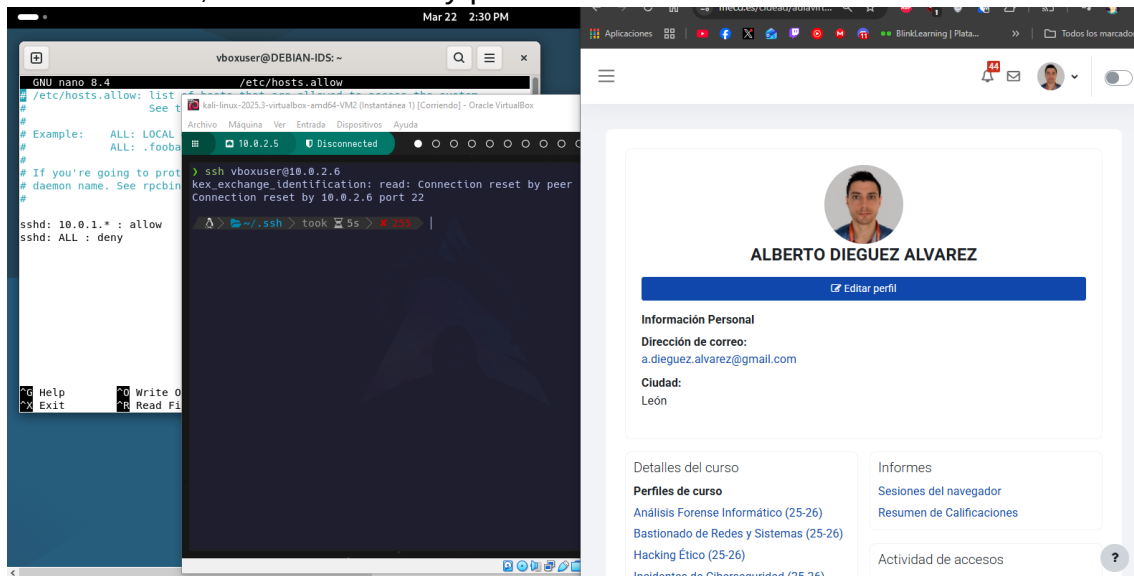
Así permito conexiones de esa IP y rechazo otras.



Compruebo que puedo hacer ssh:



Modifico la IP, reinicio servicio y pruebo.

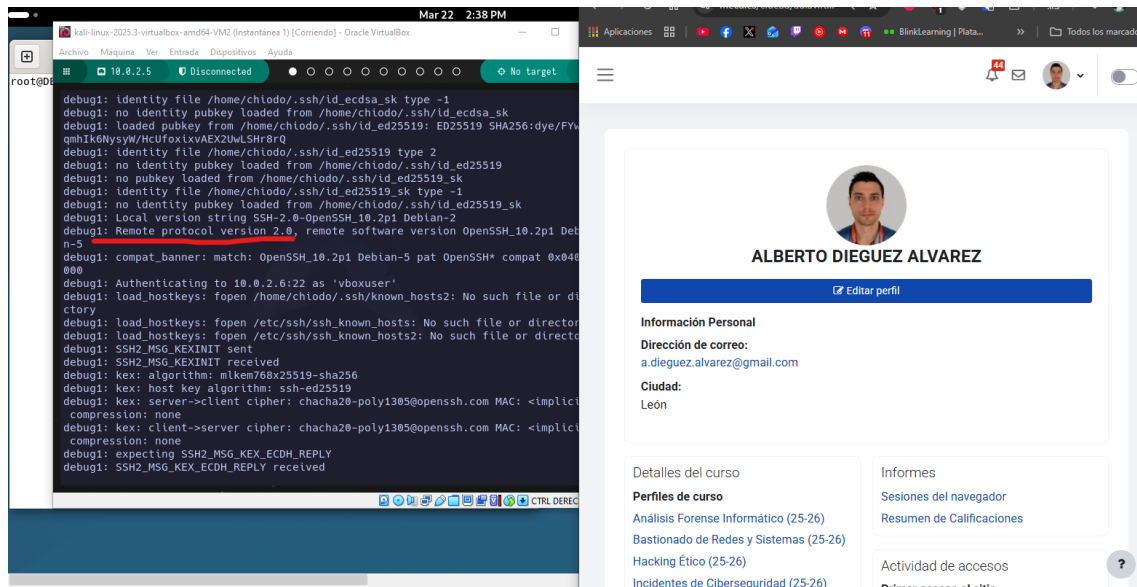


Al tener otro rango de IPs configurado, no me deja.

6. Se debe implementar la versión segura del protocolo.

Al ejecutar `ssh -v vboxuser@10.0.2.5` podemos ver en modo 'verbose' lo que va haciendo y podemos ver que tiene el protocolo 2 que es la versión segura.

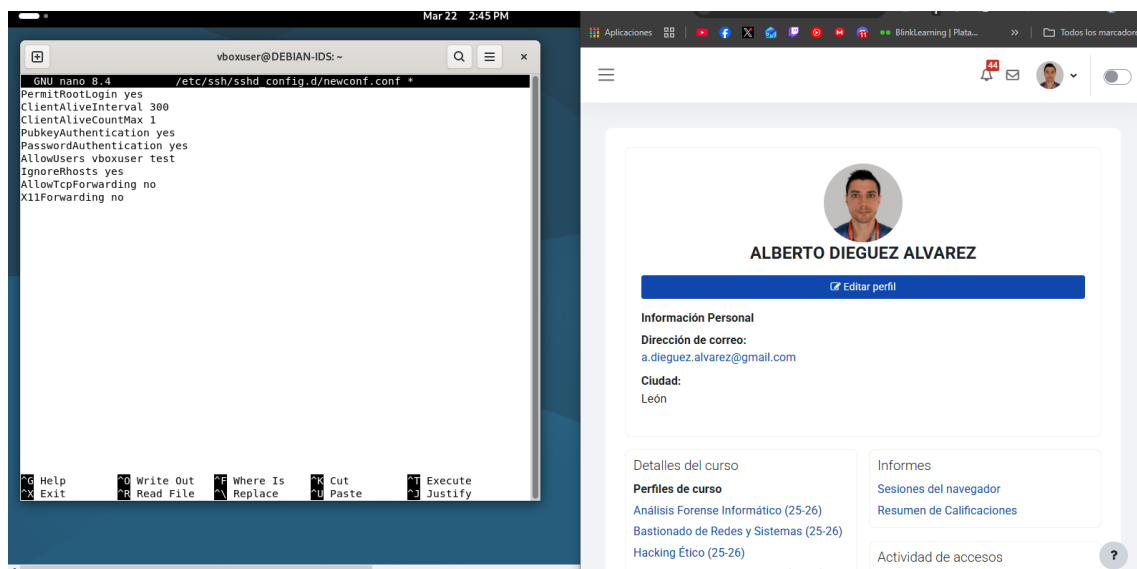
Por lo que me he informado el 'Protocol 1' está obsoleto, y por defecto solo está disponible 'Protocol 2'



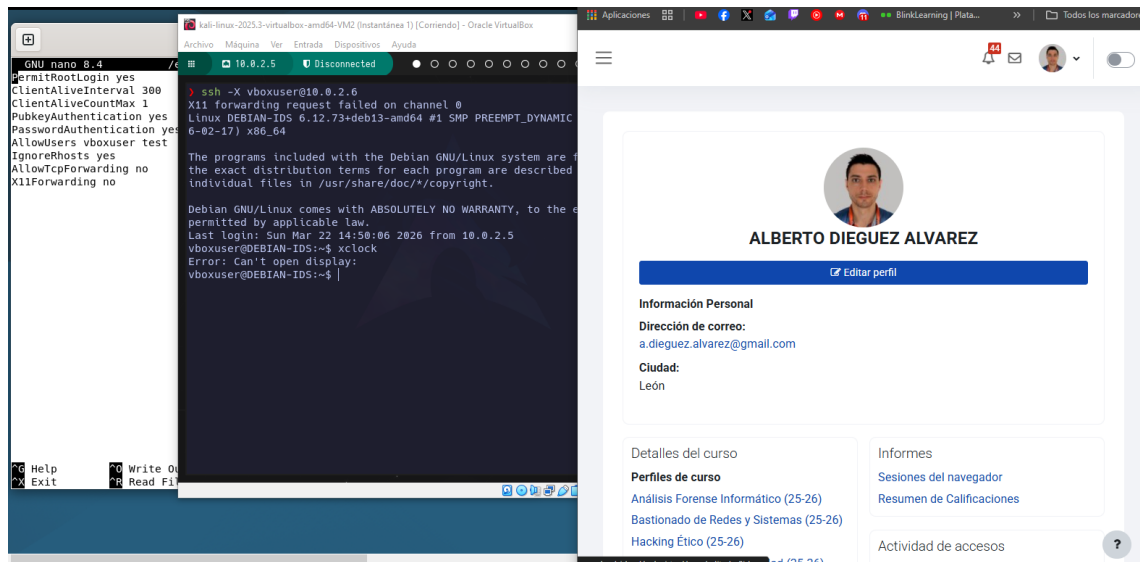
7. No es posible que a través del servicio se realice “Port-forwarding” ni “X11 Forwarding”.

Configuro el mismo archivo:

AllowTcpForwarding no
X11Forwarding no

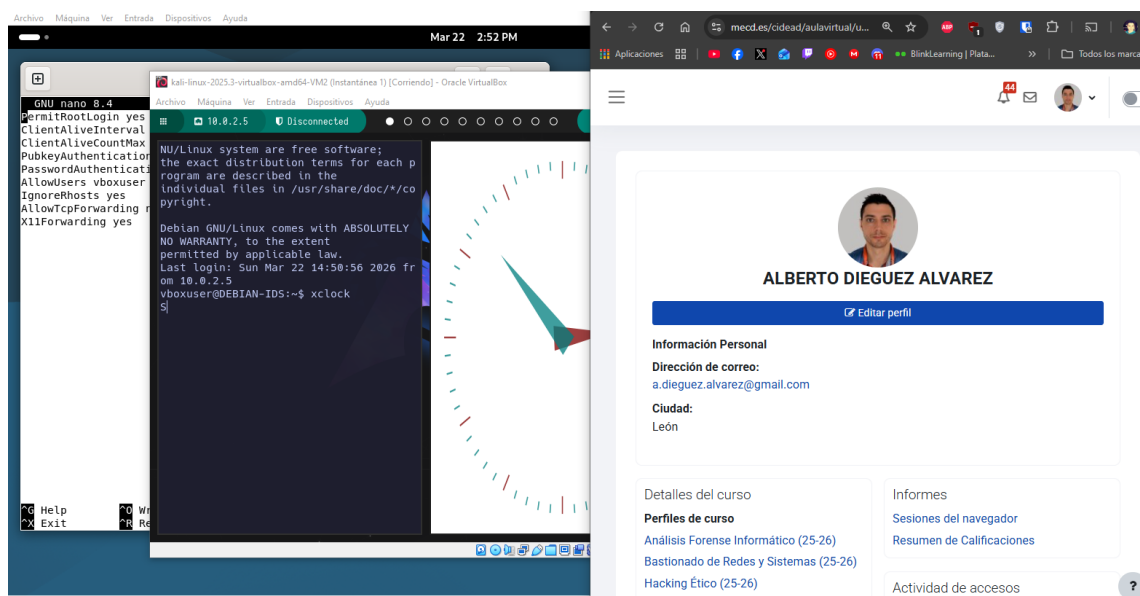


Y tengo este resultado:



Y ahora habilito:

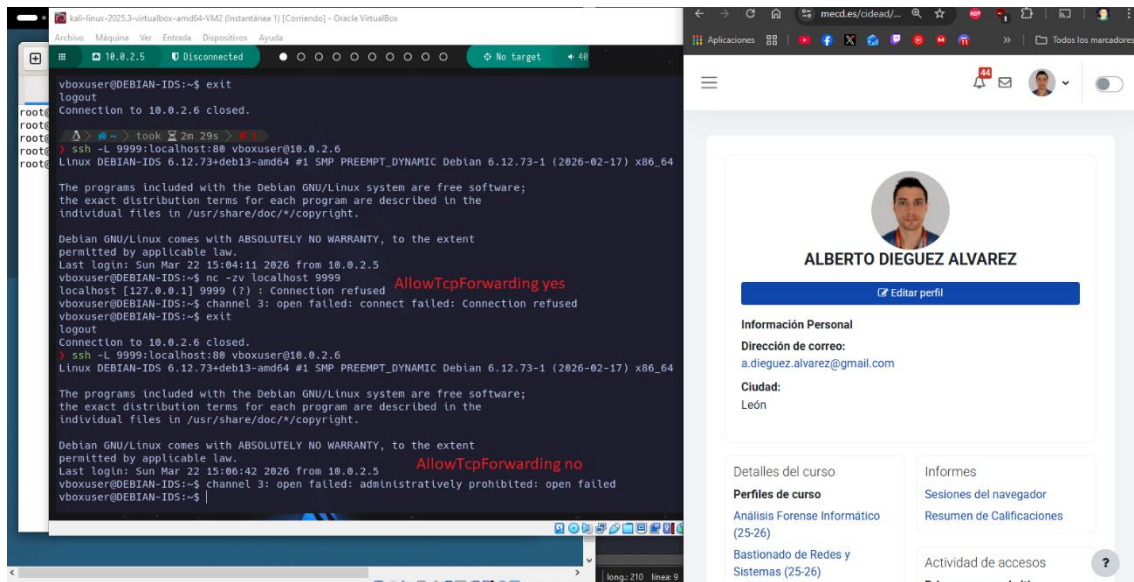
X11Forwarding yes



Ahora pruebo

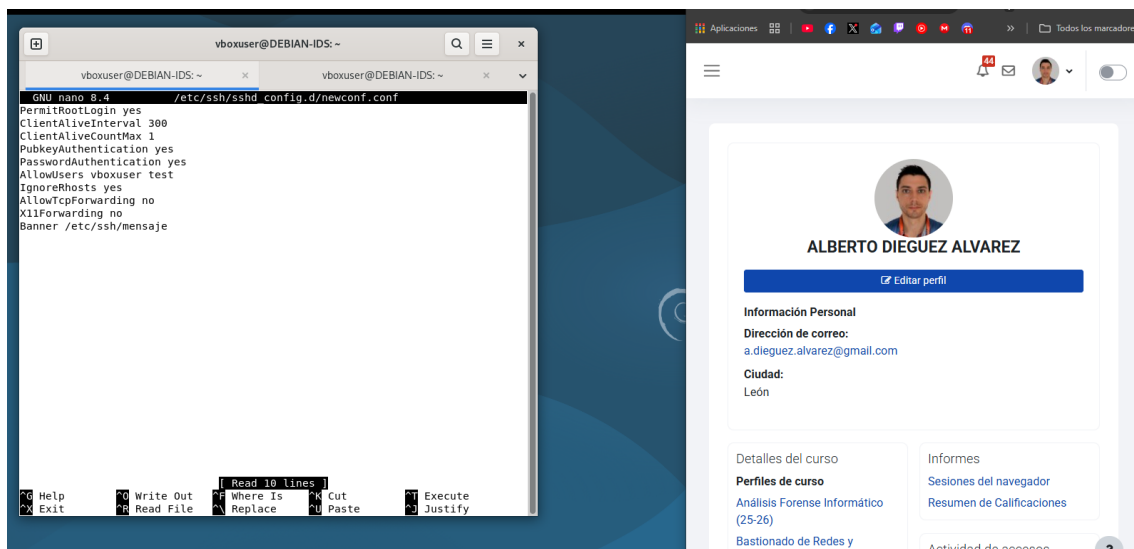
AllowTcpForwarding

Realizo la prueba en la misma consola, primero pruebo NO y después yes, y se ve la respuesta.

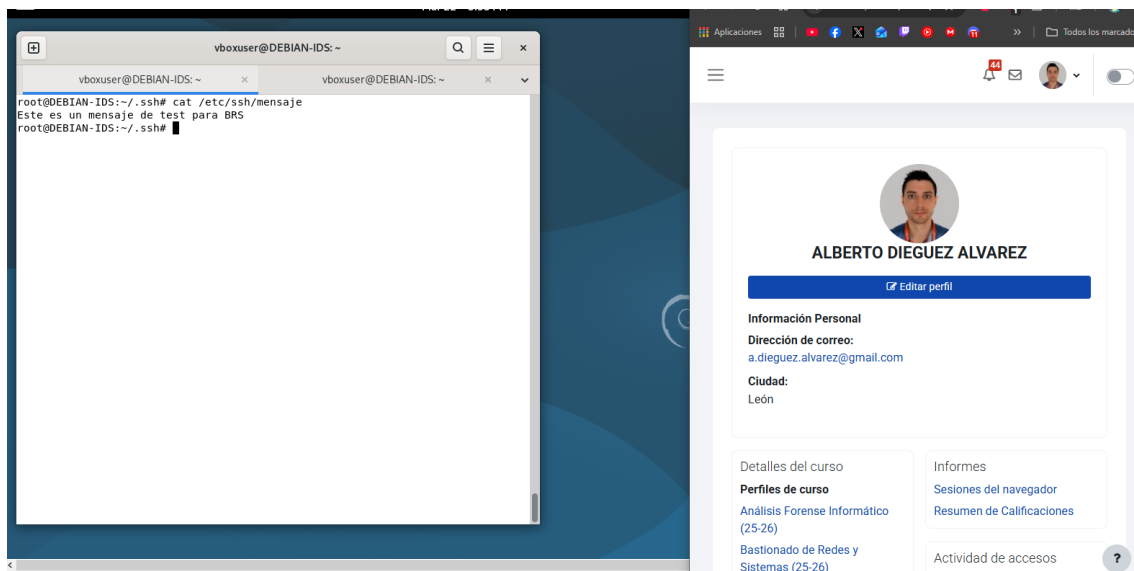


8. Los usuario recibirán en el inicio de sesión recibirán un mensaje indicando al tipo de sistema que están accediendo y las obligación de cumplir con la normativa interna de la empresa.

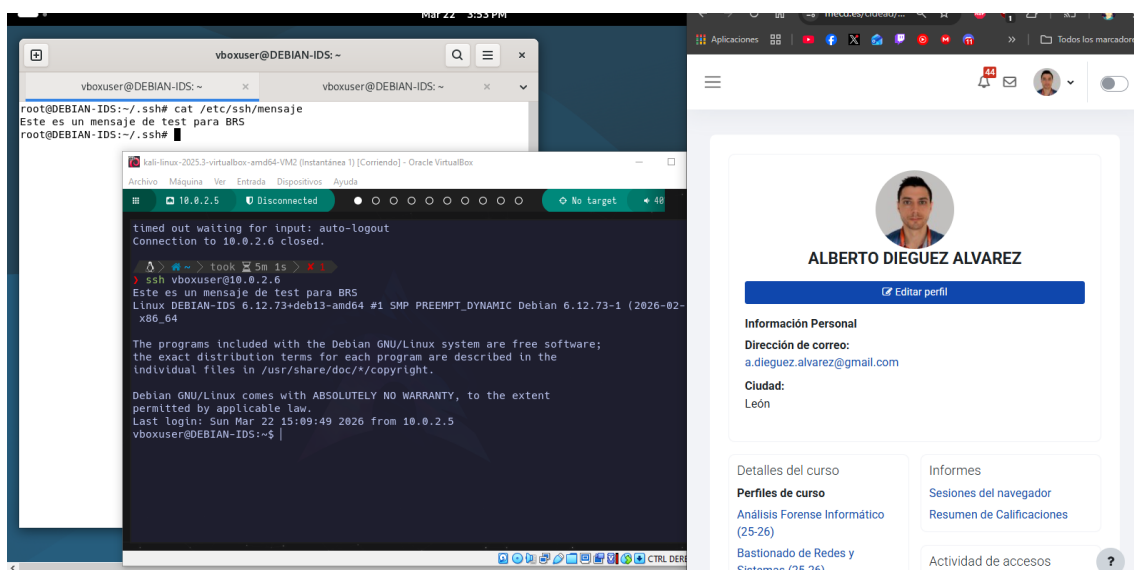
Con la etiqueta `Banner` configuramos el mensaje en las conexiones ssh.



Aquí se indica la ruta del archivo que contiene el mensaje, ahora creamos el archivo.



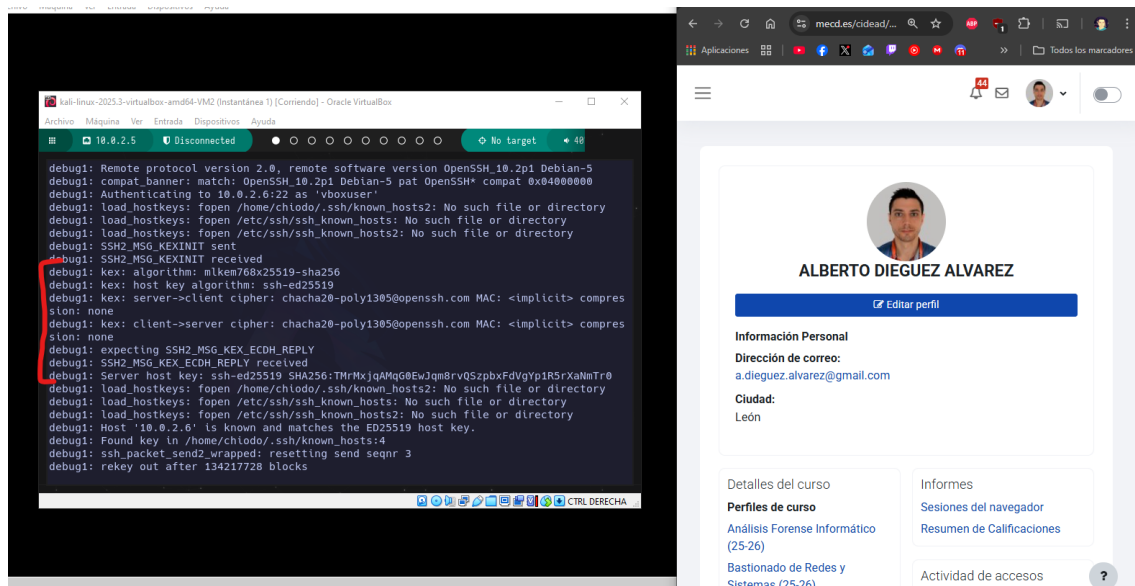
Ahora ejecutamos ssh desde la VM Kali.



Se puede ver el mensaje.

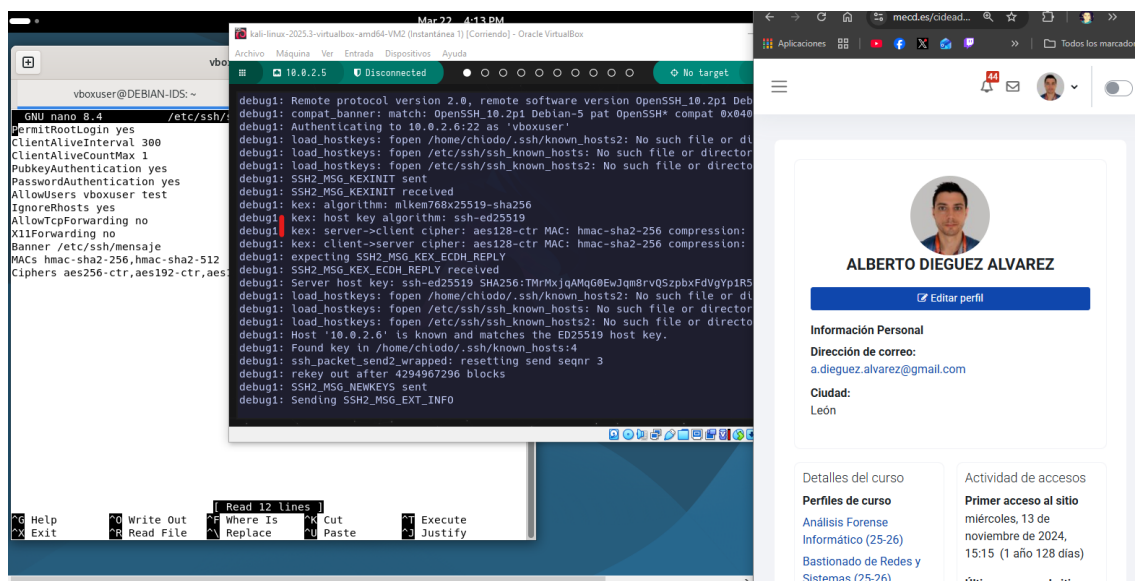
9. Se establecerán los algoritmos de hash SHA2-512 y SHA2-256 para garantizar la integridad de los datos...

Comprobamos los que tenemos ahora mismo.



Añadimos `MACs hmac-sha2-512,hmac-sha2-256` a la configuración y comprobamos. Haciendo pruebas he visto que no se ejecutaban los cambios, y parece ser que también hay que limitar los Ciphers, si no estos los ignoran. Entonces añadido también `Ciphers aes256-ctr,aes192-ctr,aes128-ctr`.

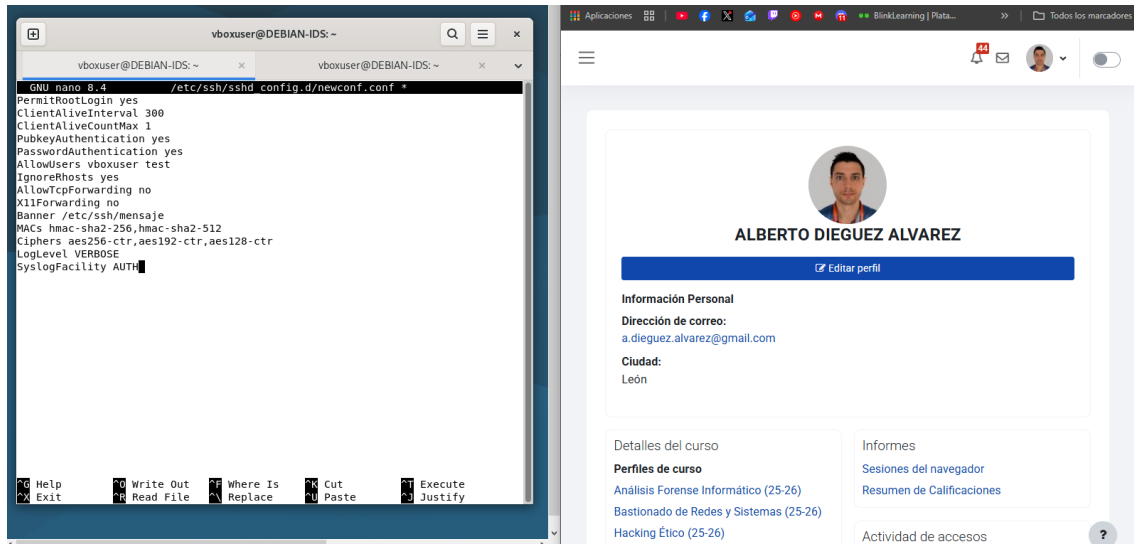
Ahora después de añadir los Ciphers ya se ve en los logs.



10. Los logs del servicio están activados para poder enviárselos al SOC.

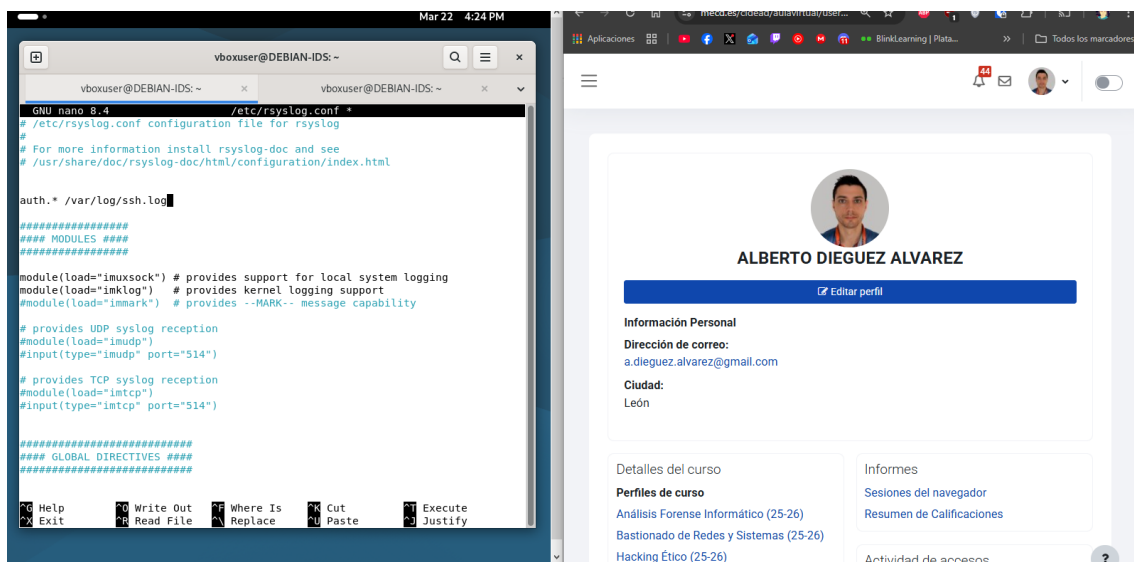
Configuramos la VM Debian.

LogLevel VERBOSE
SyslogFacility AUTH
Quedaría así configurado:

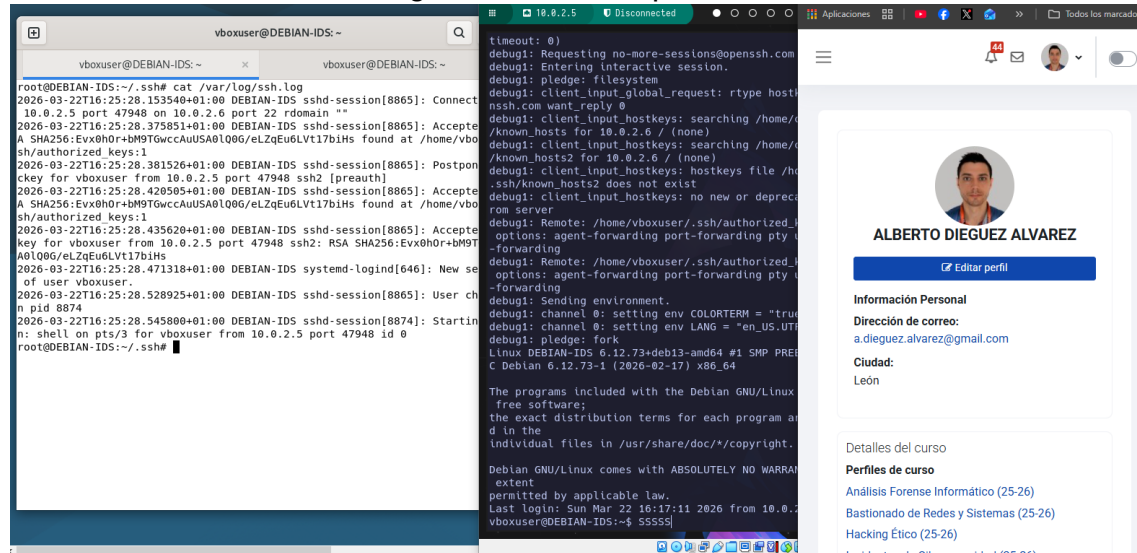


Ahora instalo `rsyslog`, me voy a `/etc/rsyslog.conf` y añado esto:
`auth.* /var/log/ssh.log`

Con esto conseguimos: con `auth` que nos muestre los logs de los servicios de autenticación y con `*` le indicamos que todo y que lo envíe a la ruta que le indicamos, reiniciamos servicio y probamos.



Al conectarnos vemos los logs en el archivo que indicamos:

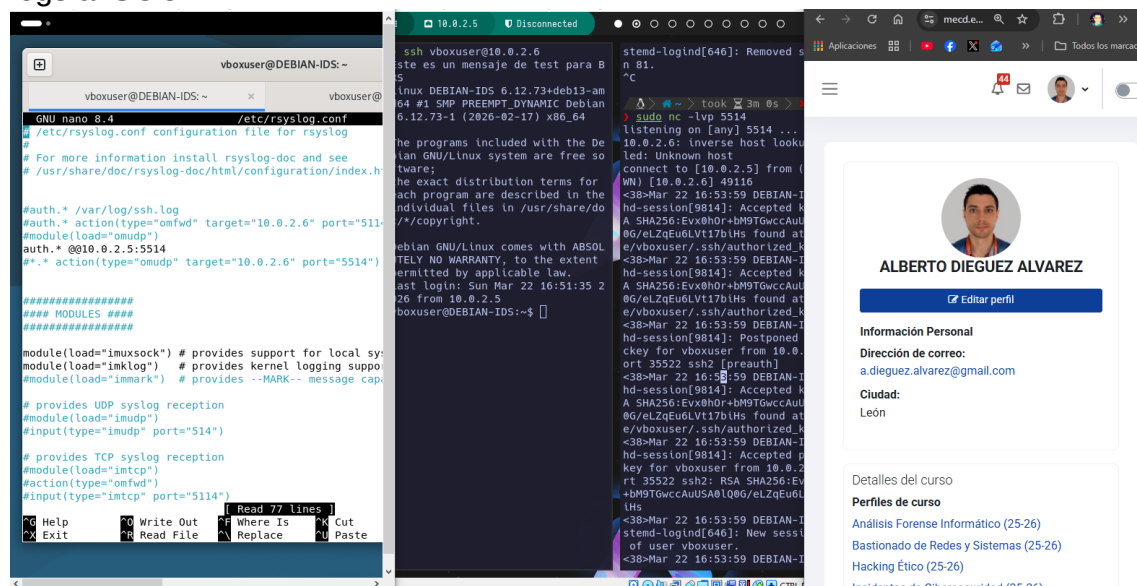


The screenshot shows a terminal window with the following content:

```
vboxuser@DEBIAN-IDS:~  
vboxuser@DEBIAN-IDS:~  
root@DEBIAN-IDS:~# cat /var/log/ssh.log  
2026-03-22T16:25:28.153540+01:00 DEBIAN-IDS sshd-session[8865]: Connect  
10.0.2.5 port 47948 on 10.0.2.6 port 22 rdomain ""  
2026-03-22T16:25:28.375851+01:00 DEBIAN-IDS sshd-session[8865]: Accepted  
A SHA256:Evx8h0r+bM9TGwccAuSA0L0Q6/eLZqEu6LVt17b1Hs found at /home/vbo  
sh/authorized_keys:1  
2026-03-22T16:25:28.381526+01:00 DEBIAN-IDS sshd-session[8865]: Postpon  
ckey for vboxuser from 10.0.2.5 port 47948 ssh2 [preauth]  
2026-03-22T16:25:28.420505+01:00 DEBIAN-IDS sshd-session[8865]: Accepted  
A SHA256:Evx8h0r+bM9TGwccAuSA0L0Q6/eLZqEu6LVt17b1Hs found at /home/vbo  
sh/authorized_keys:1  
2026-03-22T16:25:28.435620+01:00 DEBIAN-IDS sshd-session[8865]: Accepted  
key for vboxuser from 10.0.2.5 port 47948 ssh2: RSA SHA256:Evx8h0r+bM9T  
A0L0Q6/eLZqEu6LVt17b1Hs  
2026-03-22T16:25:28.471318+01:00 DEBIAN-IDS systemd-logind[646]: New ses  
sion of user vboxuser.  
2026-03-22T16:25:28.528925+01:00 DEBIAN-IDS sshd-session[8865]: User ch  
n pid 8874  
2026-03-22T16:25:28.545800+01:00 DEBIAN-IDS sshd-session[8874]: Startin  
g: shell on pts/3 for vboxuser from 10.0.2.5 port 47948 id 0  
root@DEBIAN-IDS:~# sshd  
timeout: 0)  
debug1: Requesting no-more-sessions@openssh.com  
debug1: Entering interactive session.  
debug1: pledge: filesystem  
debug1: client_input_global_request: rtype hostkeys-  
nssh.com want_reply 0  
debug1: client_input_hostkeys: searching /home/v  
/known_hosts for 10.0.2.6 / (none)  
debug1: client_input_hostkeys: searching /home/v  
/known_hosts2 for 10.0.2.6 / (none)  
debug1: client_input_hostkeys: hostkeys file /h  
/ssh/known_hosts2 does not exist  
debug1: client_input_hostkeys: no new or deprec  
rom server  
debug1: Remote: /home/vboxuser/.ssh/authorized_k  
options: agent-forwarding port-forwarding pty v  
-forwarding  
debug1: Remote: /home/vboxuser/.ssh/authorized_k  
options: agent-forwarding port-forwarding pty v  
-forwarding  
debug1: Sending environment.  
debug1: channel 0: setting env COLORTERM = "true  
debug1: channel 0: setting env LANG = "en_US.UT  
debug1: pledge: fork  
Linux DEBIAN-IDS 6.12.73+deb13-amd64 #1 SMP PRE  
C Debian 6.12.73-1 (2026-02-17) x86_64  
The programs included with the Debian GNU/Linux  
free software;  
the exact distribution terms for each program ar  
d in the  
individual files in /usr/share/doc/*/copyright.  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANT  
extent  
permitted by applicable law.  
Last login: Sun Mar 22 16:17:11 2026 from 10.0.2  
vboxuser@DEBIAN-IDS:~$ SSSSS
```

On the right, there is a user profile page for ALBERTO DIEGUEZ ALVAREZ. The page includes a profile picture, a name, a button to edit the profile, and sections for personal information, course details, and course profiles. The personal information section shows the email address a.dieguez.alvarez@gmail.com and the city León. The course details section shows the course name and the course profiles section shows the course name and the course profiles.

Y por último tras probar varias cosas. Pongo la VM Kali en escucha por el puerto 5514 con `nc -lvp 5514`, configuro la VM Debian para envíe por TCP al puerto 5514 los logs de auth con `auth.\* @@10.0.2.5:5514` y nos llegan los logs al SOC.



The screenshot shows a terminal window with the following content:

```
vboxuser@DEBIAN-IDS:~  
vboxuser@DEBIAN-IDS:~  
GNU nano 4.4 /etc/rsyslog.conf  
#etc/rsyslog.conf configuration file for rsyslog  
# For more information install rsyslog-doc and see  
# /usr/share/doc/rsyslog-doc/html/configuration/index.h  
#auth.* /var/log/ssh.log  
#auth.* action(type="omfwd" target="10.0.2.6" port="5514"  
module(load="omudpf")  
auth.* @10.0.2.5:5514  
#*. * action(type="omudpf" target="10.0.2.6" port="5514")  
#####  
#####  
module(load="imuxsock") # provides support for local sy  
module(load="imklog") # provides kernel logging suppo  
module(load="immark") # provides --MARK-- message cap  
# provides UDP syslog reception  
module(load="imudp")  
input(type="imudp" port="514")  
# provides TCP syslog reception  
module(load="imtcp")  
action(type="omfwd")  
input(type="imtcp" port="514")  
Help Write Out Read 77 lines  
Exit Read File Where Is Replace Cut Paste
```

On the right, there is a user profile page for ALBERTO DIEGUEZ ALVAREZ. The page includes a profile picture, a name, a button to edit the profile, and sections for personal information, course details, and course profiles. The personal information section shows the email address a.dieguez.alvarez@gmail.com and the city León. The course details section shows the course name and the course profiles section shows the course name and the course profiles.